

# Information Security Policy

**Organization:** Rough Cut Manufacturing ("the Company"), operator of the WorkTrackPro application

**Policy Owner:** Jacob Rough, Chief Executive Officer — jacobrrough@gmail.com

**Version:** 1.0 **Effective Date:** June 17, 2026 **Next Review:** June 17, 2027

**Approved by:** Jacob Rough, CEO — June 17, 2026

## 1. Purpose

This policy defines how Rough Cut Manufacturing identifies, mitigates, and monitors information security risks to protect the confidentiality, integrity, and availability of the data it holds — including customer, job/manufacturing, accounting, and financial-account data obtained via integrated providers (e.g., Plaid, QuickBooks Online). It is reviewed and enforced on an ongoing basis (see §14).

## 2. Scope

Applies to all employees, contractors, and systems that store, process, or transmit Company or customer data, including the WorkTrackPro web application, its Supabase backend, Netlify hosting and serverless functions, source-code repositories, and all devices used to access these systems.

## 3. Roles & Responsibilities

- **Policy Owner / Security Officer** (Jacob Rough, CEO) is accountable for information security: maintaining this policy, owning the risk review, managing access, and coordinating incident response.
- **All staff and contractors** must follow this policy, use unique credentials with multi-factor authentication, protect their devices, and report suspected security incidents to the Policy Owner immediately.
- Security responsibilities are re-evaluated whenever roles change.

## 4. Risk Management (identify · mitigate · monitor)

The Company operates a continuous, documented risk process:

- **Identify:** Maintain an inventory of systems, data types, and third-party providers that handle sensitive data (Supabase, Netlify, Plaid, QuickBooks Online, GitHub). Classify data as Public, Internal, or **Sensitive** (customer PII, accounting records, and financial-account data/credentials).
- **Mitigate:** Apply the controls in §§5–13 commensurate with data sensitivity; financial-account data and access tokens receive the strongest controls (encryption, server-side-only handling, least privilege).
- **Monitor:** Review automated security signals (dependency alerts, provider status, access logs) on an ongoing basis, and conduct a formal risk review at least annually and upon any material change (new integration, new data type, or security incident). Findings and remediation actions are recorded by the Policy Owner.

## 5. Access Control & Authentication

- **Unique accounts** for every user via Supabase Auth; no shared logins.
- **Least privilege & RBAC:** Application access is governed by role (administrator and scoped accounting roles) and enforced in the database with Row-Level Security (RLS). Server-only privileges (service-role keys) are never exposed to the browser.
- **Multi-factor authentication (MFA)** is required for administrators signing in to the WorkTrackPro application — TOTP (authenticator app), enforced at the login gate — and for all administrative consoles that can access production systems or sensitive data: Supabase, Netlify, GitHub, and the Plaid and QuickBooks dashboards. An administrator can reset a user's application MFA if a device is lost.
- **Provisioning / Deprovisioning:** Access is granted on a need-to-know basis and revoked promptly when a user leaves or changes roles.

## 6. Data Protection & Encryption

- **In transit:** All traffic is encrypted with TLS 1.2 or higher (enforced by Netlify and Supabase).
- **At rest:** Production data is encrypted at rest (AES-256) by the hosting provider (Supabase/AWS). Sensitive third-party access tokens (e.g., Plaid, QuickBooks) are additionally encrypted at the application layer (AES-256-GCM) before storage and are accessible only to server-side functions — never returned to client browsers.
- **Secrets management:** API keys and credentials are stored as environment variables in the hosting platform, never committed to source code.
- **Use limitation:** Financial data obtained from providers is used solely to deliver the Company's bookkeeping/accounting features and is accessible only to authorized administrators.

## 7. Third-Party / Vendor Management

The Company relies on reputable infrastructure and integration providers and reviews their security posture before and during use. Primary providers (Supabase, Netlify, Plaid, Intuit/QuickBooks, GitHub) maintain industry-recognized compliance (e.g., SOC 2). The vendor inventory and provider data handling are reviewed during the annual risk review or when a new provider is added.

## 8. Vulnerability & Patch Management

- **Dependencies:** Automated dependency vulnerability scanning (GitHub Dependabot) runs against the code repository; flagged vulnerabilities are triaged and remediated on a risk-prioritized basis.
- **Infrastructure:** Production runs on managed platforms (Supabase, Netlify) that patch underlying servers; the Company keeps application dependencies current.
- **Endpoints:** Company and contractor devices run supported operating systems with automatic updates and endpoint protection (e.g., built-in OS antivirus/firewall) enabled.

## 9. Secure Development & Change Management

- Source code is version-controlled in Git/GitHub; changes are reviewed before reaching production.
- Automated quality and safety gates (type checking, linting, tests, and build verification) must pass before release.
- Development and production environments are separated; production secrets are never used in development.

## 10. Privacy & Consent

- The Company maintains a published Privacy Policy describing what data is collected and how it is used (see the Company's Privacy Policy).
- Consumer consent for connecting financial accounts is obtained through the provider's authorization flow (e.g., Plaid Link) and applicable Company terms; data is collected and processed only for the stated purpose (accounting / bookkeeping).

## 11. Data Retention & Deletion

Sensitive data is retained only as long as needed for business and legal/accounting obligations and then deleted, per the Company's Data Retention & Deletion Policy. Financial-account connections can be revoked at any time; disconnecting a provider removes the stored access credentials and unlinks the associated accounts.

## 12. Incident Response

- Suspected incidents are reported immediately to the Policy Owner.
- Response steps: **contain** (revoke credentials/tokens, disable affected access), **assess** scope and affected data, **remediate** the root cause, and **notify** affected parties, providers (including Plaid where required), and regulators as required by law and contract.
- Each incident and its resolution are documented for the next risk review.

## 13. Backup & Continuity

Production data is backed up automatically by the hosting provider (Supabase), with point-in-time recovery available to restore service after data loss or corruption.

## 14. Policy Review & Enforcement

This policy is reviewed at least annually and after any material change, and is updated as needed by the Policy Owner. Violations may result in revoked access and, for staff/contractors, disciplinary action. Exceptions must be approved in writing by the Policy Owner.

*Document control: maintained by the Policy Owner (Jacob Rough, CEO). Supersedes all prior versions.*